FICHE TUTEUR · PROJET SUIVI D'INCIDENTS BACKBONE

Semaine 3

Blade, Bootstrap et authentification

Durée : 5 jours Routes Contrôleurs Blade Bootstrap Sessions Sécurité

Intentions pédagogiques

L'apprenant voit enfin quelque chose s'afficher : la motivation remonte. Profitez-en pour introduire la **sécurité** dès maintenant (CSRF, échappement, sessions) : c'est plus facile que de corriger de mauvaises habitudes plus tard.

L'authentification est volontairement écrite **à la main** (sans Breeze) : 3 méthodes, 20 lignes. L'objectif est qu'il comprenne ce qu'un starter kit fait à sa place.

Déroulé conseillé

Jour	Activité
J1	Routes, contrôleurs, `route:list`. Layout Blade minimal avec Bootstrap CDN.
J2	Menu complet, page active, zone d'alertes flash. Composant `<x-badge>`.
J3	`LoginController` : formulaire et connexion.
J4	Déconnexion, groupes `auth` / `guest`, throttle. Exercice sur la table `sessions`.
J5	Responsive, finitions, point hebdomadaire.

Corrigé : fichiers de référence

- `app/Http/Controllers/Auth/LoginController.php`
- `routes/web.php`
- `resources/views/layouts/app.blade.php`, `resources/views/auth/login.blade.php`
- `resources/views/components/badge.blade.php`

Organisation des routes attendue :

```php
Route::middleware('guest')->group(function () {
    Route::get('/login', [LoginController::class, 'create'])->name('login');
    Route::post('/login', [LoginController::class, 'store'])->middleware('throttle:5,1');
});

Route::middleware('auth')->group(function () {
    Route::post('/logout', [LoginController::class, 'destroy'])->name('logout');
    Route::get('/', DashboardController::class)->name('dashboard');
    // ... toutes les autres routes
});
```

Déconnexion complète :

```php
Auth::logout();
$request->session()->invalidate();
$request->session()->regenerateToken();
```

Page active dans le menu : `@if(request()->routeIs('incidents.*')) active @endif`.

Corrigé de l'exercice MySQL

- Connecté : une ligne dans `sessions` avec son `user_id`.
- Déconnecté : la session est invalidée ; une nouvelle session **anonyme** (user_id NULL) apparaît pour la page de connexion.
- `users.password` contient un **hash bcrypt** (`$2y$12$…`) : fonction à sens unique, on ne peut que comparer, pas déchiffrer. Si la base fuit, les mots de passe ne sont pas lisibles directement.

Erreurs fréquentes

Erreur	Symptôme	Piste
`@csrf` oublié	« 419 Page Expired »	Chaque formulaire POST/PUT/DELETE
Déconnexion par un lien `<a>`	Fonctionne mais vulnérable	Un GET ne doit jamais modifier l'état
Route `login` sans nom	`Route [login] not defined` lors d'une redirection	Le middleware `auth` cherche la route nommée `login`
Bootstrap JS absent	Le menu déroulant ne s'ouvre pas	Charger `bootstrap.bundle.min.js` en bas de page
`{!! $titre !!}`	Faille XSS	Démontrer avec un titre `<script>alert(1)</script>`
Mot de passe comparé en clair	Code avec `where('password', ...)`	Utiliser `Auth::attempt`

Questions pour le point hebdomadaire

1. **À quoi sert le jeton CSRF ? Montre-le dans le code source de la page.** *Attendu :* empêcher un site tiers de soumettre un formulaire à la place de l'utilisateur connecté. Champ caché `_token`.
2. **Pourquoi régénérer la session à la connexion ?** *Attendu :* éviter la fixation de session (un attaquant qui connaîtrait l'identifiant de session avant connexion).
3. **Quelle différence entre `{{ }}` et `{!! !!}` ?** *Attendu :* le premier échappe le HTML (sûr), le second l'affiche brut (risque XSS).
4. **Que fait `redirect()->intended()` ?** *Attendu :* renvoie vers la page initialement demandée avant la redirection vers la connexion.
5. **Comment fonctionne `throttle:5,1` ?** *Attendu :* 5 requêtes par minute ; au-delà, réponse 429.

Grille d'évaluation (sur 20)

Critère	Points
Layout commun propre, menu avec page active, responsive	4
Connexion fonctionnelle avec erreurs en français	4
Déconnexion en POST, session invalidée	2
Routes protégées (`auth` / `guest`)	3
Throttle sur la connexion	1
Composant `<x-badge>` réutilisable, messages flash	2
Compréhension sécurité à l'oral (CSRF, XSS, session)	4

Adapter le rythme

- **En avance** : « Se souvenir de moi », puis une page « Mon profil » pour changer son mot de passe (avec vérification de l'ancien).
- **En difficulté** : fournir le layout complet ; il se concentre sur le `LoginController` et les routes.